



UNIVERSITAT
Carlemany



UNIVERSITAT

Diseño y optimización de una arquitectura de red segura basada en principios Zero Trust para un despacho de servicios jurídicos

Segmentación, control de acceso y detección de intrusiones

Alumno: Joel Angel Balboa Arrojo

Tutor: Francisco Manuel Collazos Gámiz

Bàtxelor en Informàtica
Semestre 2. Edició 2025 - 2026
Junio 2026

ÍNDICE

ÍNDICE	2
1. Introducción y contextualización del proyecto	3
1.1. Descripción y situación inicial	3
1.2 Problema detectado y necesidades del cliente	4
1.3. Posibles soluciones valoradas	5
1.4. Design Thinking: empatizar, definir e idear	5
1.5. Diagrama de Ishikawa	7
1.6. Diagrama DAFO	8
2. Alcance del proyecto	9
2.1 Qué incluye el proyecto	9
2.2 Qué queda fuera del proyecto	10
2.3. Resumen elementos incluidos - excluidos del proyecto	12
2.4. Recursos disponibles y limitaciones	12
2.5 Requisitos Funcionales y No funcionales	14
2.6 Objetivos SMART y OKR	15
3. Planificación del proyecto	18
3.1. Lista de tareas e hitos	18
3.2. Dependencias entre tareas	19
3.3. Diagrama de Gantt	20
3.4. Diagrama PERT o camino crítico	21
4. Bibliografía de referencia	22
5. Anexos	23

1. Introducción y contextualización del proyecto

"Diseño y optimización de una arquitectura de red segura bajo principios Zero Trust para un despacho de servicios jurídicos: Segmentación, control de acceso y detección de intrusiones"

1.1. Descripción y situación inicial

Con el presente trabajo se busca abordar el diseño y la optimización de una arquitectura de red segura para una PYME del sector jurídico, aplicando principios acotados de Zero Trust e incorporando un sistema de detección de intrusiones mediante herramientas gratuitas y de código abierto, en un entorno de laboratorio simulado. Para comprobar el diferente nivel de exposición entre la situación inicial y la final se realizará una acotada auditoría de seguridad mostrando los puntos más importantes entre las dos situaciones.

El punto inicial, del que partimos es una infraestructura de red completamente plana, sin ninguna segmentación de red, seguridad en control de acceso ni monitorización del tráfico.

Con este escenario inicial buscamos reproducir la situación real de muchas PYMES y con más énfasis a las que tratan con información sensible y a su vez, sirviéndonos de base para poder comparar, la mejora de seguridad que puede aportar la solución propuesta.

La empresa sobre la que trabajaremos es una PYME ficticia con nombre Legal JBA y Asesores, tratándose de un despacho jurídico multidisciplinar de 18 empleados distribuidos en seis áreas: Mercantil, Laboral, Fiscal y Civil. El sector jurídico ha sido elegido especialmente porque presenta una justificación natural y sólida para la aplicación de principios Zero Trust, tratando información confidencial, protegida por el secreto profesional y que contiene datos de carácter personal especialmente sensibles en el sentido del Reglamento General de Protección de Datos (RGPD) y donde cada abogado debe tratar solo los expedientes que estén relacionados con su área.

La red actual de Legal JBA y Asesores responde a un modelo típico de crecimiento, partiendo inicialmente de unos pocos trabajadores y equipos hasta el actual estado, incorporando empleados, ampliando equipos, un servidor de expedientes y servicios de conectividad a medida que el despacho ha crecido, sin que en ningún momento se haya diseñado una arquitectura que contemple el control de acceso, la segmentación o la visibilidad del tráfico.

1.2 Problema detectado y necesidades del cliente

La situación descrita en el anterior apartado deriva en un problema central claramente identificable, la red de Legal JBA y Asesores presenta una exposición elevada ante accesos no autorizados y movimientos laterales, internos como externos, sin ningún mecanismo que permita detectarlos ni contenerlos.

El origen de esta exposición se analiza en los siguientes puntos además, vemos las siguientes necesidades concretas del cliente:

1. Necesidad de separación lógica en los recursos:

La red plana actual permite que cualquier dispositivo conectado acceda a los demás sin restricción. Se necesita segmentar la red de forma que los diferentes elementos (PCs, Servidor, Wi-Fi, Impresoras, Cámaras...) sean accesibles entre ellos solo si previamente se ha permitido, operando sino en entornos aislados y sin opción a poder saltar entre los diferentes elementos de red.

2. Control de acceso basado en el principio de mínimo privilegio:

No se debería poder acceder a recursos fuera de su área de trabajo. Se necesita un esquema de control de acceso que, a nivel de red, garantice que cada segmento funcional solo tenga visibilidad sobre los recursos estrictamente necesarios para su actividad.

3. Visibilidad y detección de comportamiento anómalo:

Actualmente el despacho no dispone de ningún mecanismo que le permita detectar accesos no autorizados, escaneos internos o movimientos laterales entre equipos. Se necesita una solución de monitorización que genere alertas ante tráfico sospechoso y tengamos trazabilidad de los eventos de que ocurren en la red.

4. Aislamiento de la red de invitados:

Como se ha comentado en el primer punto, actualmente existe una red lineal donde el servicio de Wi-Fi ofrecido a terceros es el mismo que el Wi-Fi interno corporativo. Se necesita una red de invitados que ofrezca acceso únicamente a internet y esté completamente aislada del resto de la infraestructura del despacho.

5. Acceso remoto seguro y controlado:

Los trabajadores que acceden remotamente a los recursos del despacho lo hacen a través de medios no controlados, VPN básica sin autenticación adicional, Anydesk, Teamviewer... Se necesita unificar el servicio a una solución VPN segura y reforzar este con medidas mínimas de verificación adicional.

6. Solución viable con recursos limitados:

El despacho no dispone de presupuesto histórico en seguridad ni de personal especializado. Cualquier solución debe ser implementable con herramientas de código abierto, sin coste de licencias, y gestionable por un equipo de IT reducido.

1.3. Posibles soluciones valoradas

Como posibles soluciones encontramos las siguientes:

- Solución 1:

Contratar una solución de seguridad gestionada de un proveedor que incluya firewall, gestión de identidad, IDS, segmentación como servicio...

Esta opción puede cubrir todas las necesidades identificadas, pero presenta un gran obstáculo para el contexto del proyecto. El coste de servicio, licencias y hardware es elevado para una PYME sin un presupuesto en comunicaciones y seguridad, siendo inviable aplicar soluciones en un espacio corto de tiempo, con lo que puede implicar seguir con la actual dinámica.

- Solución 2:

Realizar la segmentación on-premise con herramientas open source y principios Zero Trust acotados.

Diseñar e implementar en un entorno de laboratorio simulado (GNS3/EVE-NG) una arquitectura de red segmentada mediante VLANs, con firewall por zonas, control de acceso basado en roles, acceso remoto reforzado y despliegue de Suricata como sistema de detección de intrusiones. De esta forma, el coste es mínimo, con opción a ver si la mejora proporcionada es válida y pudiendo aplicarla en un corto espacio tiempo.

1.4. Design Thinking: empatizar, definir e idear

Con el fin de definir una solución alineada con las necesidades reales del cliente, se ha aplicado la metodología **Design Thinking**, centrando el análisis en las tres primeras fases: **empatizar, definir e idear**. Este enfoque permite comprender el contexto del despacho jurídico, identificar el problema principal y valorar distintas alternativas antes de seleccionar la solución que se desarrollará durante el proyecto.

Empatizar

Con la primera fase buscamos comprender el entorno de trabajo del cliente y que necesidades existen y condicionan la solución que buscamos aplicar.

Al tratarse de un despacho jurídico la actividad diaria de este implica el tratamiento continuo de documentos confidenciales, expedientes judiciales, contratos, información económica...

También vemos que, parte del personal necesita acceder ocasionalmente a los recursos corporativos desde ubicaciones externas, y que clientes y colaboradores utilizan la red inalámbrica de invitados cuando acuden a las oficinas.

La prioridad del despacho no consiste únicamente en proteger la infraestructura informática, sino en garantizar la confidencialidad de la información de sus clientes sin aumentar la complejidad de gestión ni realizar grandes inversiones.

A partir de este análisis se identifican las principales necesidades del cliente:

- Proteger la información confidencial frente a accesos no autorizados.
- Limitar la comunicación entre departamentos aplicando el principio de mínimo privilegio.
- Disponer de un acceso remoto seguro para el personal autorizado.
- Separar completamente la red corporativa de la red destinada a invitados.
- Detectar comportamientos anómalos o intentos de acceso indebidos mediante mecanismos de monitorización.
- Implantar una solución técnicamente viable utilizando herramientas de código abierto y un coste reducido.

Estas necesidades complementan las descritas en el anterior apartado 1.2, permitiendo comprender no solo los problemas técnicos que existen, sino también las limitaciones organizativas y económicas de la empresa.

Definir

Tras analizar el contexto general del despacho, se identifica un problema principal que resume la situación actual de la infraestructura.

La red corporativa ha evolucionado conforme el despacho ha ido creciendo, ampliando los equipos y servicios sin una planificación específica de red y seguridad. Como consecuencia, todos los dispositivos comparten un mismo segmento de red y existe una confianza implícita entre ellos.

Esta situación nos muestra que existen diversos riesgos:

- Cualquier dispositivo puede comunicarse con el resto de la red y por tanto comprometerla de diferentes formas .
- Los usuarios disponen de una visibilidad superior a la necesaria.
- No existen herramientas capaces de detectar movimientos laterales o actividades sospechosas.
- El acceso remoto se realiza mediante herramientas inseguras y sin controles adicionales.
- La red inalámbrica utilizada por invitados comparte recursos con la red corporativa.

En consecuencia, el problema que buscamos abordar podría definirse como:

La infraestructura de red de Legal JBA y Asesores presenta una elevada exposición frente a accesos no autorizados y movimientos laterales debido a la ausencia de segmentación, control de acceso y mecanismos de monitorización de seguridad.

Idear

Con el problema identificado, se establecen diferentes soluciones teniendo en cuenta las necesidades del cliente, las limitaciones presupuestarias y el alcance establecido.

En primer lugar, se valoró la posibilidad de implantar una solución comercial completamente gestionada, integrando firewall de nueva generación, sistemas de detección de intrusiones, gestión centralizada de identidades y otros mecanismos avanzados de seguridad. Aunque esta alternativa proporciona un elevado nivel de protección, requiere una inversión económica significativa y un nivel de especialización técnica que no resulta compatible con el escenario planteado.

Como segunda alternativa, se estudió el diseño de una arquitectura basada en herramientas de código abierto, implementada en un entorno de laboratorio.

Esta opción permite reproducir un escenario representativo, aplicar principios de Zero Trust de forma acotada y validar si existe una mejora de seguridad mediante auditorías de seguridad antes y después de la implementación.

Tras comparar ambas posibilidades, se selecciona la segunda alternativa al ofrecer un equilibrio adecuado entre seguridad, viabilidad técnica y coste de implantación. La solución propuesta contempla la segmentación de la red mediante VLAN, la aplicación de políticas de firewall, el aislamiento de la red de invitados, la incorporación de un acceso remoto seguro y el despliegue de Suricata como sistema de detección de intrusiones.

Esta propuesta permite responder a las necesidades identificadas durante las anteriores fases de empatía y definición, manteniendo un alcance realista y plenamente alineado con los objetivos del proyecto.

1.5. Diagrama de Ishikawa

Con el objetivo de identificar las causas originarias del problema principal, se ha elaborado el siguiente diagrama de Ishikawa.

Este análisis permite representar de forma estructurada los factores relacionados con la tecnología, el entorno, los procesos, las alertas, las personas y la gestión, todos factores que contribuyen a la elevada exposición de la infraestructura de red frente a accesos no autorizados y movimientos laterales.

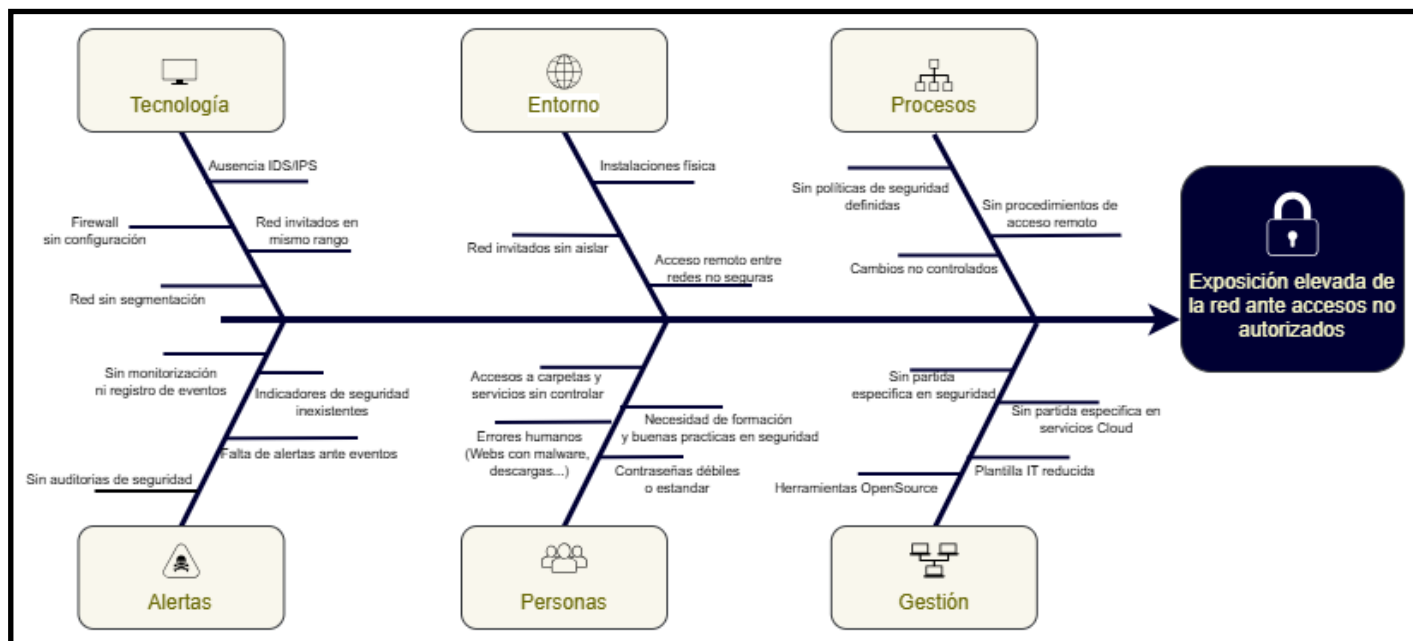


Figura 1. Diagrama de Ishikawa. *Elaboración propia.*

1.6. Diagrama DAFO

Complementando la anterior Figura1. Diagrama de Ishikawa, se presenta la siguiente Figura2. Análisis DAFO, que permite evaluar la situación actual de Legal JBA y Asesores desde una perspectiva más estratégica.

Este análisis identifica las fortalezas y debilidades internas, las oportunidades y las amenazas externas, permitiendo una correcta adecuación y justificación de la solución propuesta a las necesidades del cliente.

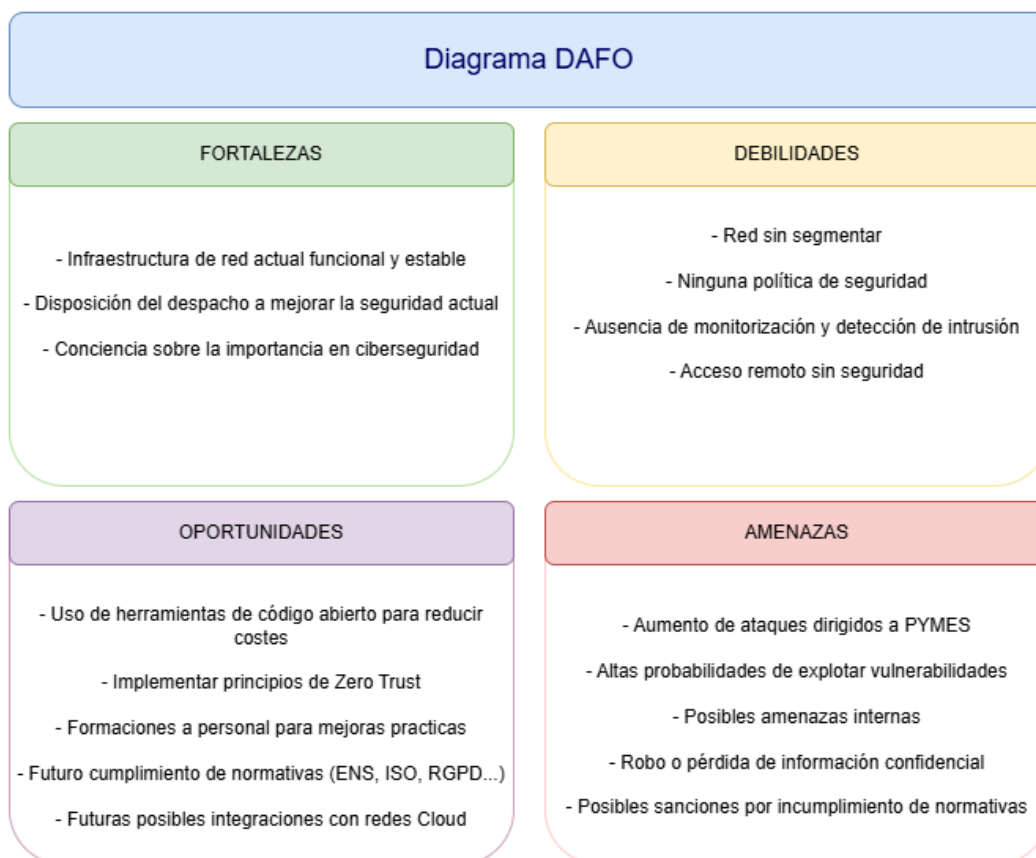


Figura 2. Análisis DAFO — Legal JBA y Asesores. *Elaboración propia.*

2. Alcance del proyecto

2.1 Qué incluye el proyecto

El proyecto se centra en el diseño, implementación y validación de una arquitectura de red segura para el despacho jurídico ficticio Legal JBA y Asesores, configurado en un entorno virtualizado de laboratorio, partiendo de una red inicial completamente plana y sin segmentación.

Los elementos que forman parte del alcance son los siguientes:

- **Diseño de topología segmentada:**

Definición de un diseño de red dividida en zonas diferenciadas mediante zonas y VLANs: áreas jurídicas (Mercantil, Laboral, Fiscal, Civil), administración/IT, servidores y red de invitados.

Se incluye la situación inicial con el diagrama de red base y el diagrama con la solución final objetivo, la tabla de direccionamiento y las reglas de comunicación entre segmentos.

- **Implementación en entorno de laboratorio simulado:**

Toda la implementación se realizará en un entorno simulado mediante GNS3 o EVE-NG. Se incluye la configuración de los elementos de red virtuales necesarios: switches

con soporte de VLANs, firewall con las políticas entre zonas y los dispositivos finales representativos que sean necesarios en cada segmento.

- Control de acceso a nivel de red:

Aplicación de principios de mínimo privilegio mediante reglas de firewall y ACLs entre VLANs. Cada segmento tendrá permitido únicamente el tráfico estrictamente necesario para su función, bloqueando por defecto cualquier comunicación no autorizada entre zonas.

- Acceso remoto reforzado:

Configuración de una solución VPN como único mecanismo de acceso remoto a los recursos del despacho, sustituyendo el uso actual de herramientas no controladas (AnyDesk, TeamViewer, ...). Se añadirán medidas mínimas para la verificación de acceso.

- Red de invitados diferenciada:

Configuración de una red de invitados con acceso únicamente a internet, completamente aislada de la red corporativa interna.

- Despliegue de sistema IDS:

Instalación y configuración de Suricata como sistema de detección de intrusiones en el entorno simulado, con generación de alertas ante tráfico de prueba controlado.

- Auditoría de seguridad pre/post implementación:

Ejecución de auditorías de exposición con Nmap y OpenVAS/GVM para la situación inicial y en la situación final, utilizando las mismas herramientas y métricas para garantizar una correcta comparativa en los resultados.

Ambas auditorías se ejecutarán desde el mismo equipo atacante virtual, utilizando el mismo perfil de escaneo y desde la misma zona de red, garantizando así la comparabilidad de los resultados.

- Documentación técnica completa:

Memoria del proyecto con las decisiones de diseño justificadas, pasos de configuración, capturas de evidencia y análisis comparativo pre/post.

2.2 Qué queda fuera del proyecto

Con el siguiente apartado queremos delimitar explícitamente los elementos que podrían considerarse relevantes para una arquitectura de red segura completa pero que, quedan excluidos del alcance de este TFB.

Esta delimitación responde a criterios de viabilidad técnica, temporal y de recursos, esto no implica que dichos elementos carezcan de valor.

1. Integración con servicios cloud

La conectividad con entornos cloud, configuración de redes virtuales y la gestión de identidad mediante soluciones como Microsoft Entra ID quedan fuera del alcance de

este proyecto.

Su implementación requeriría licencias, servicios de pago y una complejidad de integración que excede los recursos disponibles y el enfoque de red on-premise del TFB. Se añade y documenta como línea de mejora futura, siendo un de los siguientes pasos lógicos una vez consolidada la arquitectura on-premise.

2. Gestión centralizada de identidad y Directorio Activo

No se implementará ningún servidor de Directorio Activo (Active Directory / LDAP) ni solución de Single Sign-On. El control de acceso se aplica íntegramente a nivel de red mediante VLANs, ACLs y reglas de firewall, que es el enfoque propio de un proyecto de diseño de red.

La gestión de identidad centralizada se propone como mejora futura complementaria a la integración cloud.

3. Alta disponibilidad y redundancia

No se contemplan configuraciones de alta disponibilidad, como enlaces redundantes, balanceo de carga o failover entre los diferentes dispositivos.

El entorno de laboratorio simulado no requiere estos elementos para validar los objetivos de seguridad definidos.

4. Explotación activa y auditoría de seguridad avanzada

La validación de la solución se limita a una breve auditoría de los servicios expuestos pre/post con Nmap y OpenVAS/GVM.

No se realizarán pruebas de penetración activa, explotación de vulnerabilidades ni análisis forense. El objetivo es solo medir la reducción de exposición, no ejecutar un test de intrusión profesional completo.

5. Despliegue sobre infraestructura real

El proyecto se desarrolla en un entorno de laboratorio simulado mediante GNS3/EVE-NG. No se realizará ninguna implementación sobre equipos físicos reales ni sobre la infraestructura de ninguna empresa.

6. Múltiples herramientas IDS/IPS en paralelo

Solo se desplegará Suricata como sistema de detección de intrusiones. No se compararán ni se implementarán soluciones IDS entre sí. El objetivo es validar el funcionamiento del IDS elegido, no realizar un análisis comparativo de herramientas.

2.3. Resumen elementos incluidos - excluidos del proyecto

TAREA	INCLUIDO EN PROYECTO	EXCLUIDO EN PROYECTO
Segmentación Vlans	X	
Firewall con zonas	X	
IDS Suricata	X	
Acceso remoto VPN seguro	X	
Aislamiento de red Wi-Fi invitados	X	
Auditoría pre-implementación	X	
Auditoría post-implementación	X	
Integración con elementos Cloud		X
AD / Gestión de identidades		X
Alta disponibilidad y redundancia		X
Despliegue en infraestructura real		X
Comparativa de herramientas		X
Pentest interno		X

2.4. Recursos disponibles y limitaciones

Las siguientes tablas exponen los recursos disponibles que se utilizarán en el proyecto.

En esta primera tratamos los recursos que se utilizan en el proyecto:

Elemento	Recurso elegido	Descripción
Base de simulación de red	GNS3 / EVE-NG	Entorno de laboratorio virtual para simular la topología de red completa
IDS/IPS	Suricata	Sistema de detección de intrusiones open source
Firewall	pfSense / OPNsense	Solución de firewall open source

Elemento	Recurso elegido	Descripción
Auditoría	Nmap, OpenVAS / GVM	Escáner de puertos, servicios y vulnerabilidades para auditoría pre/post
Software	VirtualBox / VMware / KVM	Hipervisor para alojar y gestionar los nodos de laboratorio
Hardware	Maquina personal del alumno	Máquina con los recursos necesarios y suficientes para ejecutar el entorno virtual

Para esta segunda tabla, dado que el proyecto se basa íntegramente en herramientas de código abierto y en infraestructura propia, el coste económico directo es nulo. A continuación se expone una estimación orientativa del coste interno del proyecto:

Elemento	Coste aproximado	Descripción
Licencias y software	0 €	Todas las herramientas que se tratan en el proyecto son de código abierto y gratuitas
Hardware	0 €	El equipo utilizado es el propio personal, no existe ningún coste de nuevo hardware
Servicios Cloud o alojamiento	0 €	El entorno que se prepara es totalmente en local y no es necesario adquirir soluciones Cloud
Dedicación equipo	330 Horas x 10€/H = 3.300€	Coste interno estimado, es orientativo a 30H por 11 semanas.
Otros costes adicionales	0 €	No existe ningún otro coste adicional que sea necesario para el proyecto

Como limitaciones que podemos encontrar en nuestro proyecto:

- Entorno exclusivamente simulado:

No se dispone de acceso a infraestructura física real.

Todos los resultados se obtienen en un entorno de laboratorio virtualizado, lo que implica que valores de métricas como latencia, rendimiento, carga, etc... no son extrapolables directamente a un entorno de producción real. Los resultados son válidos a efectos de comparación relativa pre/post.

- Equipo de IT reducido en el escenario ficticio:

Legal JBA y Asesores cuenta con un perfil de IT reducido y sin especialización en seguridad, lo que limita la complejidad de las soluciones que se pueden proponer

como implementables de forma autónoma por el despacho. Las soluciones elegidas priorizan la viabilidad operativa sobre la exhaustividad técnica.

- Sin presupuesto para licencias comerciales:

Todas las herramientas utilizadas son de código abierto y gratuitas. Quedan excluidas soluciones que requieran licencias de pago, suscripciones cloud o hardware específico de fabricante.

- Alcance acotado de Zero Trust:

Los principios Zero Trust se aplican de forma acotada al nivel de red: segmentación, mínimo privilegio y control de acceso por VLANs. No se implementarán otros puntos de Zero Trust como verificación continua de identidad, inspección profunda de paquetes o gestión de dispositivos endpoint entre otros.

2.5 Requisitos Funcionales y No funcionales

Los requisitos funcionales describen qué debe hacer el sistema para satisfacer las necesidades identificadas. Se indica para cada uno el criterio que permitirá verificar su cumplimiento.

ID	Requisito	Criterio comprobación
RF01	La red deberá dividirse en zonas diferenciadas: Usuarios, administración / IT, invitados	Diagrama de red final VLANs etiquetadas y reglas de comunicación
RF02	El firewall deberá aplicar reglas de filtrado entre zonas siguiendo el principio de mínimo privilegio. Permitiendo solo tráfico estrictamente necesario	Tabla de reglas permitidas y bloqueadas, con pruebas de conectividad
RF03	La red de invitados deberá estar completamente aislada de la red corporativa, permitiendo únicamente acceso a internet	Prueba de conectividad desde la red de invitados hacia recursos internos: denegado
RF04	El sistema IDS (Suricata) deberá detectar y registrar tráfico sospechoso ante pruebas controladas de escaneo interno	Capturas de alertas generadas durante las pruebas de validación
RF05	La solución deberá incluir un mecanismo de acceso remoto reforzado para el personal que trabaja fuera de la oficina	Evidencia de configuración y prueba de acceso remoto con las medidas aplicadas

Los requisitos no funcionales describen las condiciones y restricciones bajo las cuales el sistema debe operar, independientemente de su funcionalidad específica.

ID	Requisito	Criterio comprobación
RNF01	La solución deberá implementarse íntegramente con herramientas de código abierto, sin coste de licencias	Inventario de las herramientas utilizadas
RNF02	El entorno de implementación será un laboratorio simulado. No se realizará ningún despliegue sobre infraestructura real	Descripción del entorno utilizado y capturas de la topología
RNF03	La documentación generada deberá permitir reproducir la configuración básica de forma independiente	Pasos de configuración, capturas de pantalla y anexos técnicos
RNF04	La evaluación de la mejora de seguridad deberá comparar el estado inicial y el estado final utilizando las mismas herramientas y métricas	Tabla comparativa pre/post con métricas equivalentes: puertos expuestos, vulnerabilidades por severidad, alertas

2.6 Objetivos SMART y OKR

Objetivo SMART

ID OS01	Descripción
	Caracterizar la situación inicial de la red de Legal JBA
Específico	Diagrama de red base, inventario de activos y auditoría inicial
Medible	Puertos y vulnerabilidades detectadas
Alcanzable	Con herramientas: Nmap y OpenVAS/GVM en laboratorio controlado
Relevante	Nos marca una línea de inicio base pre-implementación
Temporal	Fase 1

ID OS02	Descripción
	Diseño de una topología segmentada
Específico	Creación de al menos 4 zonas diferenciadas (usuarios, administración/IT, servidores, invitados) con tabla de reglas entre zonas
Medible	Diagrama de red validado y tabla de comunicaciones
Alcanzable	Con implementación en GNS3/EVE-NG

ID OS02	Descripción
Relevante	Elimina la red plana actual y se establecen bases para las siguientes fases del proyecto
Temporal	Fase 2-3

ID OS03	Descripción
	Implementar segmentación y firewall por zonas
Específico	VLANs activas y reglas de firewall aplicando mínimo privilegio a nivel de red
Medible	Pruebas de conectividad entre las diferentes zonas, documentación de accesos permitidos y denegados
Alcanzable	Con herramientas open source en laboratorio
Relevante	Parte principal técnica del proyecto
Temporal	Fase 4

ID OS04	Descripción
	Desplegar solución IDS
Específico	Desplegar IDS Suricata operativo y configurado en el entorno simulado
Medible	Configuración de alertas y registros ante pruebas controladas de escaneo interno
Alcanzable	Herramienta open source Suricata
Relevante	Cubrir la necesidad de visibilidad del tráfico
Temporal	Fase 5

ID OS05	Descripción
	Comparar métricas de exposición pre/post
Específico	Realizar comparación con las mismas herramientas y métricas
Medible	Reducción de puertos expuestos, vulnerabilidades y accesos no autorizados entre VLANs
Alcanzable	Reproducible en laboratorio, con herramientas (Nmap y OpenVAS/GVM)
Relevante	Demostrar el valor real de la solución ofrecida.

ID OS05	Descripción
Temporal	Fase 6

ID OS06	Descripción
	Documentar decisiones técnicas y líneas futuras
Específico	Ofrecer una diferenciación clara entre el alcance implementado y lo propuesto como mejora
Medible	Apartados de limitaciones y mejoras futuras presentes en la memoria
Alcanzable	Aportando documentación necesaria
Relevante	Ofrecer futuras líneas de ampliación del proyecto
Temporal	Fase 7

Objetivo OKR

Mejorar la seguridad de la red de un despacho jurídico mediante una arquitectura segmentada con principios Zero Trust acotados, validada en entorno de laboratorio.

ID	Métrica clave
KR1	Reducir al menos un 70% el número de puertos accesibles desde la red de invitados hacia la red corporativa, medido con Nmap antes y después de la implementación
KR2	Bloquear el 100% de las pruebas de conectividad no autorizada entre VLANs, documentando cada regla de firewall aplicada y el resultado de la prueba correspondiente
KR3	Registrar al menos una alerta en Suricata por cada prueba de escaneo controlado ejecutada, con un tiempo de detección inferior a 60 segundos desde el inicio del escaneo
KR4	Presentar una tabla comparativa pre/post con un mínimo de 4 métricas equivalentes: puertos expuestos, servicios accesibles entre zonas no autorizadas, vulnerabilidades por severidad detectadas por OpenVAS/GVM, y alertas IDS generadas
KR5	Documentar posibles líneas de mejora futura con justificación técnica

3. Planificación del proyecto

3.1. Lista de tareas e hitos

El proyecto se estructura en diez fases, con tareas concretas, duración estimada y un resultado tangible que actúa como criterio de cierre de fase.

También se señalan hitos que marcan puntos de control marcados en el desarrollo del trabajo.

ID	Título	Descripción	Tiempo estimado	Entrega asociada
F1	Definir alcance del proyecto	Creación de Legal JBA y Asesores, análisis de la situación inicial, necesidades, Design Thinking, diagramas Ishikawa y DAFO	1 semana	Entregable 1
F2	Marco teórico	Revisión de conceptos clave: Zero Trust, segmentación de red, VLANs, IDS/IPS, auditoría de seguridad	1 semana	Entregable 2
F3	Preparación de la arquitectura	Diagrama de red en situación inicial y diagrama de red objetivo. Tabla de VLANs, direccionamiento y reglas de comunicación entre zonas	1 semana	Entregable 2
F4	Preparación del laboratorio	Instalación y configuración de GNS3/EVE-NG. Despliegue de switches, firewall y equipos representativos de cada segmento	1 semana	Entregable 2
F5	Auditoría inicial	Ejecución de auditoría sobre la red plana inicial. Registro de puertos expuestos, servicios accesibles detectados	2-4 días	Entregable 2
F6	Implementación principal	Configuración de VLANs, definición y aplicación de reglas de firewall con mínimo privilegio entre segmentos. Pruebas de conectividad entre zonas	1 semana	Entregable 2
F7	Acceso remoto	Creación de VPN unificada. Configuración de medidas mínimas de verificación adicional para el acceso remoto	2-4 días	Entregable 2/3
F8	Implementación IDS	Instalación y configuración de Suricata en el entorno simulado. Ejecución de pruebas controladas de escaneo interno. Registro y análisis de alertas generadas	2-4 días	Entregable 2/3
F9	Auditoría final	Ejecución de segunda auditoría sobre la red segmentada final. Elaboración de la tabla comparativa con las mismas métricas que la auditoría inicial	1 semana	Entregable 3

ID	Título	Descripción	Tiempo estimado	Entrega asociada
F10	Redacción final	Redacción de la memoria final, revisión de contenidos, entrega del TFB y preparación de defensa	3 semanas	Entregable 3

A partir de las anteriores fases, se identifican los hitos principales.

Un hito representa un punto de control concreto y que se pueda verificar, que permita confirmar que una fase o conjunto de fases ha producido el resultado esperado antes de continuar con la siguiente etapa.

Es importante señalar que las fases F2 y F3 pueden ejecutarse en paralelo durante la misma semana, al no tener dependencia entre sí. Del mismo modo, las fases F7 y F8 también pueden desarrollarse simultáneamente una vez completada la F6.

La fase F6 Implementación principal actúa como punto crítico del proyecto: cualquier retraso en esta fase afecta directamente a F7, F8 y, en consecuencia, a toda la planificación posterior.

ID	Descripción	Alcanzable
H1	Entregable 1 realizado y entregado	22/06/2026 - 28/06/2026
H2	Arquitectura diseñada y validada	05/07/2026
H3	Creación de entorno de laboratorio	12/07/2026
H4	Auditoría inicial	15/07/2026
H5	Segmentación finalizada con firewall operativo	19/07/2026
H6	Implementación completa (VPN, IDS, Wi-Fi)	20/07/2026 - 26/07/2026
H7	Comparativa pre/post completada	09/08/2026
H8	Entrega de TFB	31/08/2026 - 06/09/2026

3.2. Dependencias entre tareas

Con la siguiente tabla buscamos exponer las relaciones de dependencia que existen entre fases.

De forma general, una fase no puede iniciarse hasta que la anterior fase o fases de las que depende no estén completadas.

Fase	Dependencia	Descripción
F1. Definir alcance del proyecto	-	Punto inicial
F2. Marco teórico	F1	Necesitamos saber previamente que trabajaremos para determinar los conceptos necesarios
F3. Preparación de la arquitectura	F1	Requiere saber el escenario inicial
F4. Preparación del laboratorio	F3	Configuramos el laboratorio en base a F3
F5. Auditoría inicial	F4	Auditoría realizada sobre el laboratorio creado en la anterior fase
F6. Implementación principal	F5	Para establecer la implementación principal necesitamos antes saber de que partimos, tanto a nivel arquitectura como también vulnerabilidades
F7. Acceso remoto	F6	Integración necesaria una vez tenemos los elementos principales configurados
F8. Implementación IDS	F6	Integración que necesita la parte principal configurada
F9. Auditoría final	F7 y F8	Se requiere que todos los elementos de la solución estén implementados
F10. Redacción final	F9	Para la memoria final necesitamos integrar todos los resultados, incluida la comparativa

3.3. Diagrama de Gantt

Para establecer una correcta planificación del proyecto y que sea de forma organizada y poder garantizar el cumplimiento de los plazos, se ha elaborado el siguiente diagrama de Gantt.

En él se representan las principales fases, hitos, fecha entregables y la distribución temporal, permitiendo visualizar la secuencia de actividades necesarias para el diseño, implementación y validación de la solución propuesta.

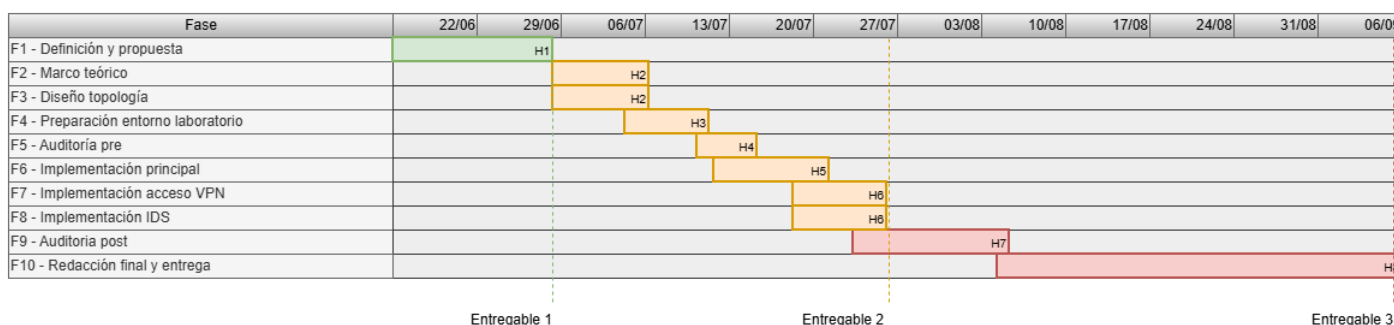


Figura 3. Diagrama de Gantt. *Elaboración propia.*

3.4. Diagrama PERT o camino crítico

Con el objetivo de identificar la secuencia lógica de ejecución del proyecto y las dependencias que existen entre las diferentes fases, se ha elaborado el siguiente diagrama PERT.

Este diagrama representa las relaciones de precedencia entre las diferentes tareas principales, permitiendo ver el camino de ejecución del proyecto y aquellas actividades cuya finalización condiciona el inicio de las fases posteriores. De este modo, facilita la planificación, el seguimiento del proyecto y la identificación de los puntos críticos durante su desarrollo.

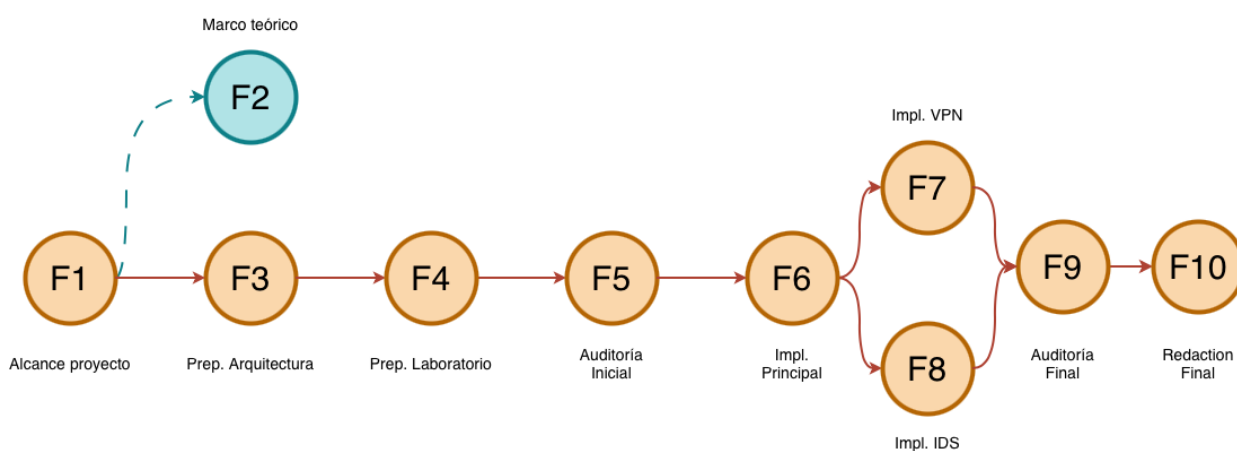


Figura 4. Diagrama de PERT. *Elaboración propia.*

Como puede observarse, el camino crítico del proyecto está formado en casi su totalidad por fases cuya finalización es necesaria para poder ejecutar la siguiente. Cualquier retraso en estas tareas afectaría directamente al calendario previsto, por lo que requieren un seguimiento prioritario durante el desarrollo del proyecto.

La única fase que se podría permitir un breve retraso es F2 Marco teórico, siendo no aconsejable ya que, obtener una buena base teórica permite que las siguientes fases puedan ser ejecutada con mayor precisión.

Por último, en el caso de F7 Implementación VPN y F8 Implementación IDS, son las únicas que no tienen dependencia una de otra, pudiendo ejecutarse en paralelo.

4. Bibliografía de referencia

Alvarez Cedillo, J. A., y Ibarra Balderas, V. M. (2012). El uso del diagrama causa-efecto en el análisis de casos. *Revista del Instituto Mexicano de Contadores Públicos*. <https://www.redalyc.org/pdf/270/27018888005.pdf>

Universidad Internacional de La Rioja (UNIR). (2025, 12 de noviembre). Diagrama de Ishikawa: qué es y cómo aplicarlo en la resolución de problemas. <https://www.unir.net/revista/empresa/ques-diagrama-de-ishikawa/>

Sánchez Huerta, D. (2020). Análisis DAFO o FODA: El mejor y más completo estudio con 9 ejemplos prácticos. Bubok Publishing. ISBN: 978-84-685-5151-3. <https://www.studocu.com/es/document/universidad-del-pais-vasco/gestion-de-empresas-iii-direccion-estrategica/sanchez-huerta-d-2020-analisis-dafo-o-foda-barcelona-editorial-bubok/94613940>

Asana. (2026). *SWOT analysis: Examples and templates*. <https://asana.com/es/resources/swot-analysis>

BBVA Innovation Center. (2015). Design Thinking [eBook gratuito en español]. BBVA. https://www.bbva.com/wp-content/uploads/2017/10/ebook-cibbva-design-thinking_es_1.pdf

Brown, T. (2008). Design Thinking. *Harvard Business Review*, 86(6), 84–92. <https://www.educaciontrespuntocero.com/libros/libros-sobre-design-thinking/>

Asana. (2026, 2 de abril). *Design Thinking Process: Stages, tips, and examples*. <https://asana.com/es/resources/design-thinking-process>

Doran, G. T. (1981). There's a S.M.A.R.T. Way to Write Management's Goals and Objectives. *Management Review*, 70(11), 35–36. <https://www.scirp.org/reference/ReferencesPapers?ReferenceID=1459599>

Canva. (s. f.). *Diagrama de Gantt: qué es y cómo hacerlo*. https://www.canva.com/es_es/pizarra-online/diagrama-gantt/

Atlassian. (s. f.). ¿Qué es un diagrama de Gantt? <https://www.atlassian.com/es/agile/project-management/gantt-chart>

Lucid Software Inc. (s. f.). ¿Qué es un diagrama PERT? <https://www.lucidchart.com/pages/es/que-es-un-diagrama-de-pert>

Salesforce. (s. f.). Diagrama de PERT: qué es, cómo funciona y cómo elaborarlo. <https://www.salesforce.com/mx/blog/diagrama-de-pert/>

Chandramouli, R., Butcher, M., y Chetal, S. (2023). *A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Cloud Environments* (NIST Special Publication 800-207A). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-207A>

GNS3 Project. (s.f.). *GNS3 Documentation: The official guide and reference for GNS3*. Recuperado el 26 de junio de 2026, de <https://docs.gns3.com>

EVE-NG Ltd. (s.f.). *EVE-NG: The first clientless multivendor network emulation software*. Recuperado el 26 de junio de 2026, de <https://www.eve-ng.net>

Netgate. (s.f.). *Virtual LANs (VLANs) — pfSense Documentation*. Recuperado el 26 de junio de 2026, de <https://docs.netgate.com/pfsense/en/latest/vlan/index.html>

OPNsense Project. (s.f.). *VLAN and LAGG Setup — OPNsense Documentation.* Recuperado el 26 de junio de 2026, de https://docs.opnsense.org/manual/how-tos/vlan_and_lagg.html

Open Information Security Foundation (OISF). (s.f.). *What is Suricata — Suricata Documentation.* Recuperado el 26 de junio de 2026, de <https://docs.suricata.io/en/latest/what-is-suricata.html>

Open Information Security Foundation (OISF). (s.f.). *Quickstart guide — Suricata Documentation.* Recuperado el 26 de junio de 2026, de <https://docs.suricata.io/en/latest/quickstart.html>

Lyon, G. (2009). *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning.* Nmap Project. ISBN: 978-0-9799587-1-7. <https://nmap.org/book/>

Greenbone Networks. (s.f.). *OPENVAS SCAN — Open Source Vulnerability Management.* Recuperado el 26 de junio de 2026, de <https://www.greenbone.net/en/openvas-scan/>

5. Anexos